

CSRF PoC for Exploiting Reflected XSS

PREREQUISITES

When Reflected XSS Becomes Exploitable

A reflected XSS becomes exploitable against another user only when all four conditions align.



Cross-Site Requests Accepted



Auth Cookies Included



No CSRF Protection



SameSite Allows Cookies



If any condition fails — e.g., **SameSite=Strict** or CSRF token required — the chain breaks.



REFLECTED XSS

Why Reflected XSS Is Usually Not Directly Exploitable

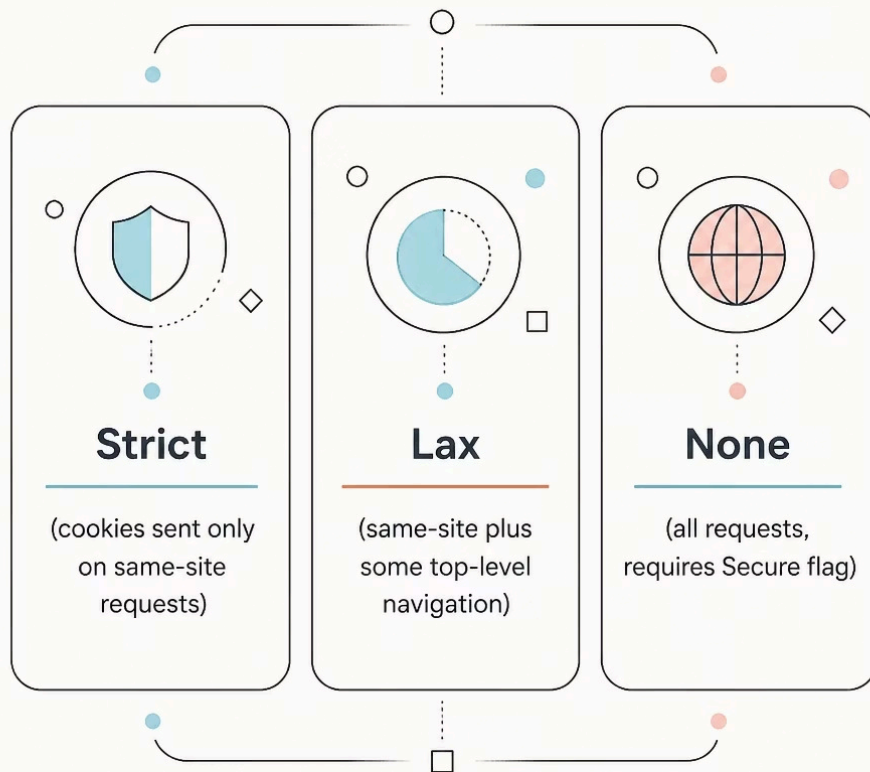
The malicious payload is **not stored** on the server; it is returned only in response to the specific request that contains it. Unlike Stored XSS, the payload exists only for the lifetime of a single request and is not persisted on the server.

- The attacker cannot cause arbitrary users to execute the payload automatically.
- Every victim must be induced to send a specially crafted request (such as by clicking a malicious link or submitting a crafted form).



PAA Reportable: Insufficient Output Encoding

SameSite Cookies & Request Methods



SameSite Controls Cross-Site Cookie Inclusion

Set-Cookie: SESSION=abc123; SameSite=Lax

Request Method Impact

Changing from **GET** to **POST** may bypass SameSite=Lax, which blocks cross-site cookies on POST requests — breaking the attack chain.

CSRF PoC: Exploiting Reflected XSS



EXAMPLE POC

Example PoC

